Task-Scoped Runtime Authorization for Industrial AI Agents

Student Name: Can Baturlar

Student ID: 2506789

1. The Purpose of the Work

An agent permitted to call a business tool may still act on the wrong record or exceed the authority of its current task. Tool-level allowlists cannot express all such restrictions. This thesis proposes an authorization gateway prototype to examine whether binding permissions to a trusted task context improves safety without excessively blocking legitimate work.

Research question: How does task-scoped authorization affect executed policy violations and legitimate task completion compared with static tool permissions?

2. Methods and Materials

The prototype will mediate between one AI agent and a simulated industrial order service. It will inspect proposed tool calls, evaluate their names and arguments against trusted permissions, allow or reject execution, and log decisions for evaluation. The resettable service will expose four tools: read an order, check inventory, create a draft, and update a draft. The system will compare three conditions: tool-name allowlists; tool-name and static argument restrictions; and the same restrictions augmented with task-specific record identifiers and operation limits. A trusted application will supply task permissions independently of model output. Every tool execution will pass through the gateway before reaching the service.

An initial target of approximately 80 held-out scenarios will pair authorized requests with controlled attempts to access unrelated records or exceed quantity limits. Both clean and manipulated tool responses will be included. Policies and prompts will be frozen after a separate development set. Conditions will use the same agent model, tools, initial database states, and step budget, with three repetitions per scenario. A separate database audit will determine actual effects rather than rely on agent claims. Measurements will include executed violations, legitimate task completion, rejected authorized calls, and added latency. Paired comparisons and scenario-level bootstrap confidence intervals will assess differences. Incorrect or incomplete trusted task contexts will be tested separately as a sensitivity analysis.

3. Expected Results

Expected outputs are an enforcement adapter, a bounded policy representation, and evidence on the protection-overblocking trade-off of task-bound permissions. Results will identify where contextual restrictions add value beyond static argument checks. Conclusions will depend on complete mediation and correct policy inputs; the study will not claim that a gateway alone makes arbitrary agents safe.